SECURITY



OCP L.O.C.K. and FIPS

Gwangbae Choi *Samsung Electronics*



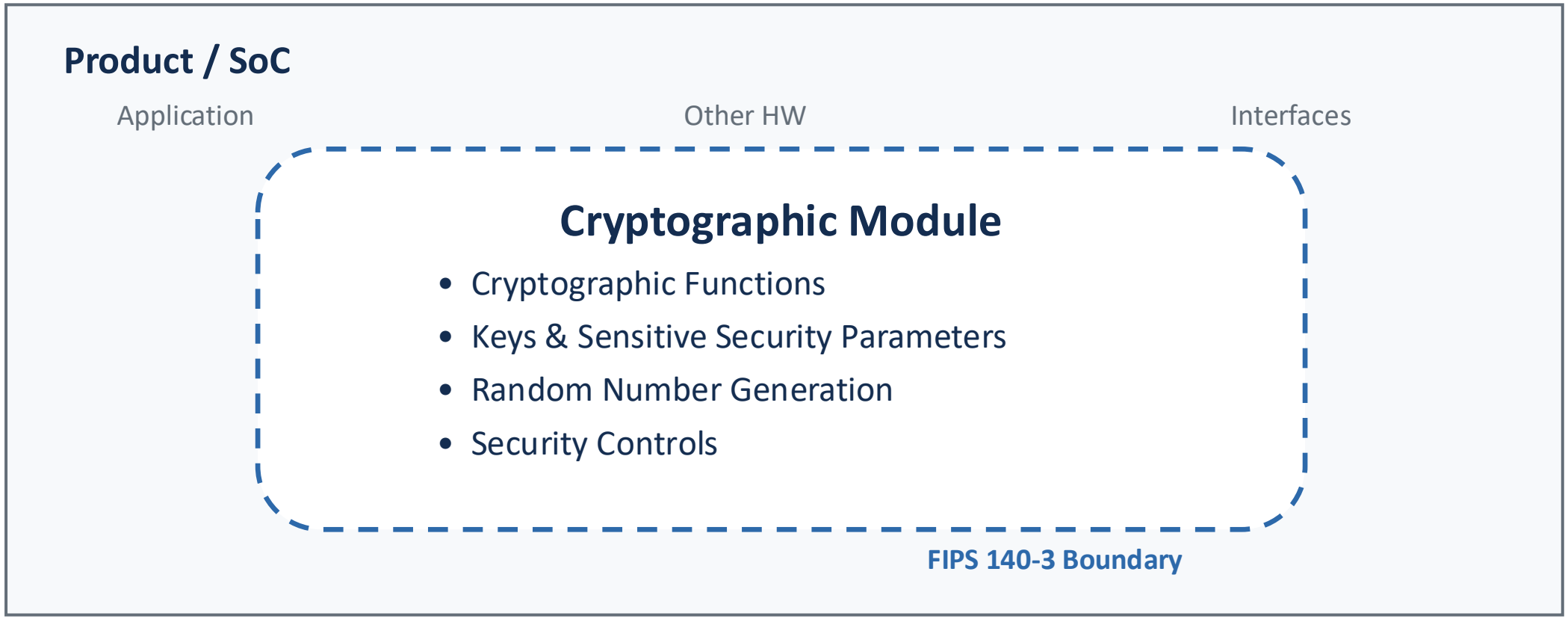
Why FIPS 140-3 Matters for OCP L.O.C.K.

* Federal Information Processing Standards

* Layered Open-source Cryptographic Key-management

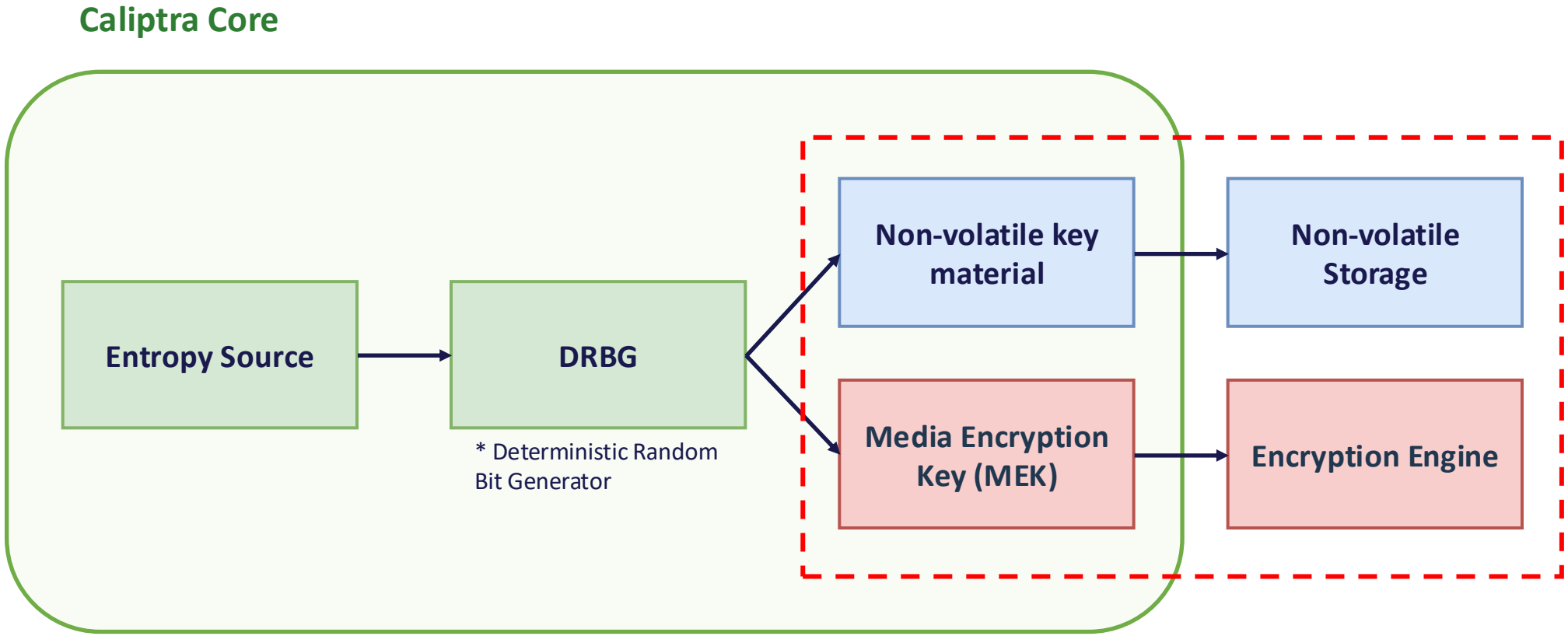
- **FIPS 140-3** is the U.S. federal standard that specifies security requirements for hardware, software, and firmware **cryptographic modules**.
- FIPS 140-3 is a **deployment requirement** in many regulated and hyperscale environments.
- **OCP L.O.C.K.** is an open industry specification that, in conjunction with **OCP Caliptra**, is designed to secure **data at rest** in enterprise storage devices.
- OCP L.O.C.K. protects **media-encryption keys** by moving **key management** into a trusted hardware architecture.
- Our discussion focuses on **FIPS 140-3 Security Level 2 or higher**.
- The FIPS question is not only **“which algorithms?”** — it is also **“where is the cryptographic module boundary?”**

What Does FIPS 140-3 Validate?



FIPS 140-3 validates the defined cryptographic module — not necessarily the entire product.

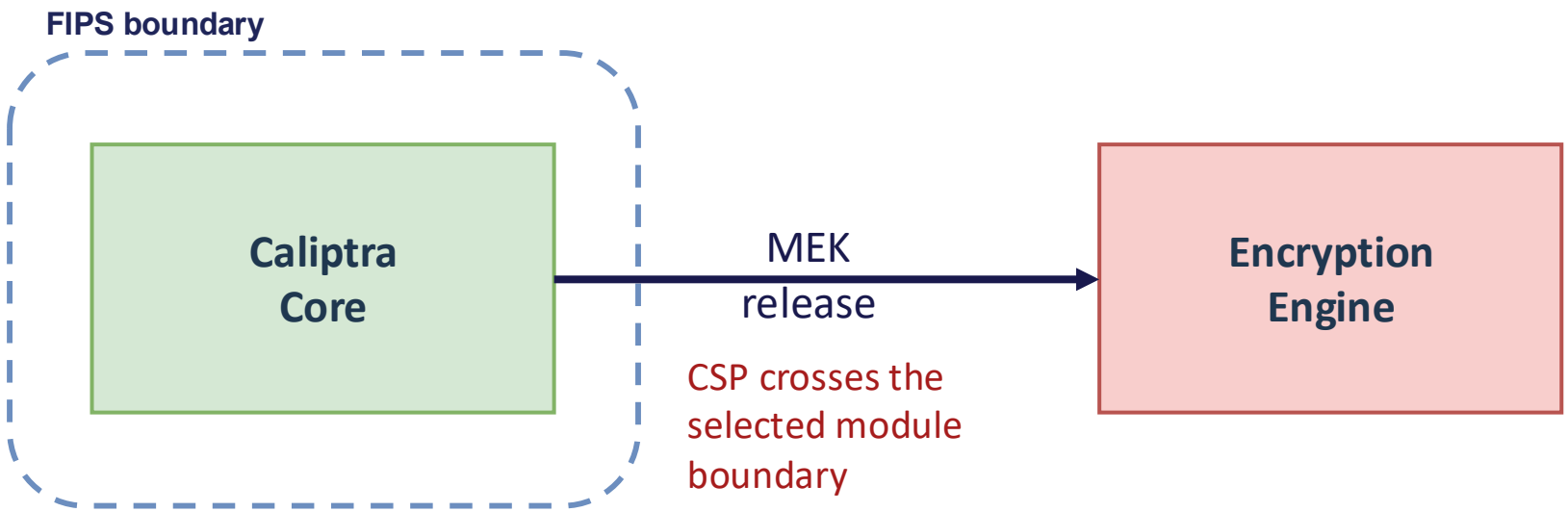
OCP L.O.C.K. Extends the Key Lifecycle



FIPS must account for both kinds of Critical Security Parameter (CSP) output:

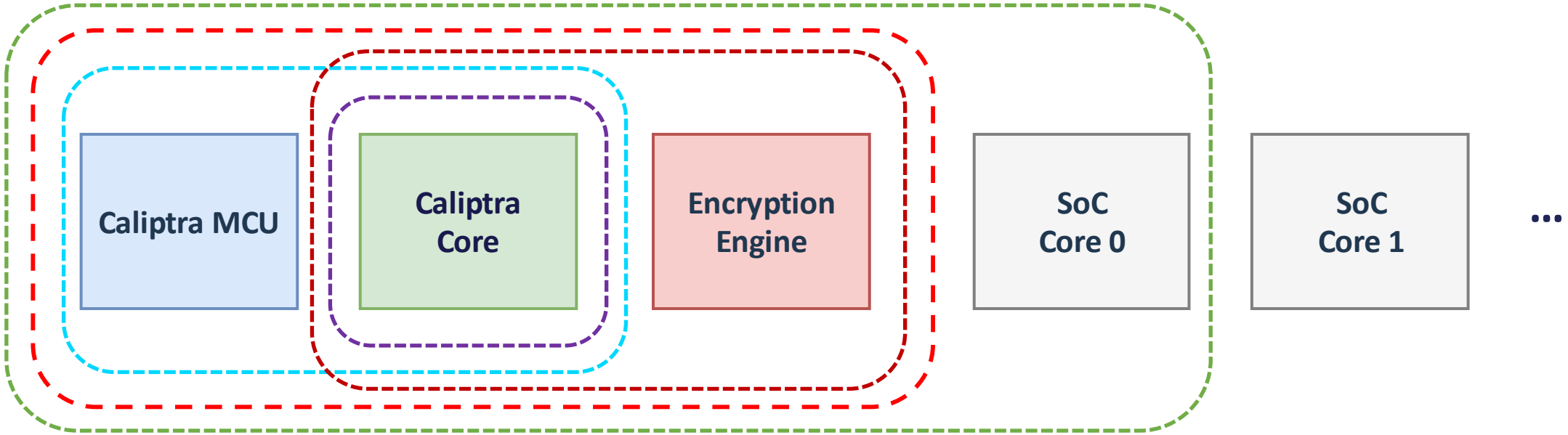
- protected / encrypted CSP (e.g., keys) entry / export
- controlled MEK release to the encryption engine

Where Does the FIPS Module End?



L.O.C.K. turns the cryptographic-module boundary into a system-level design decision.

Same SoC, Different FIPS Boundaries



Examples: Caliptra | Caliptra + MCU | Caliptra + MCU + Encryption Engine | Caliptra + Encryption Engine | + selected SoC cores

The selected boundary changes what is validated, what is external, and which integration assumptions must be validated.

Choosing the Boundary: The Trade-off

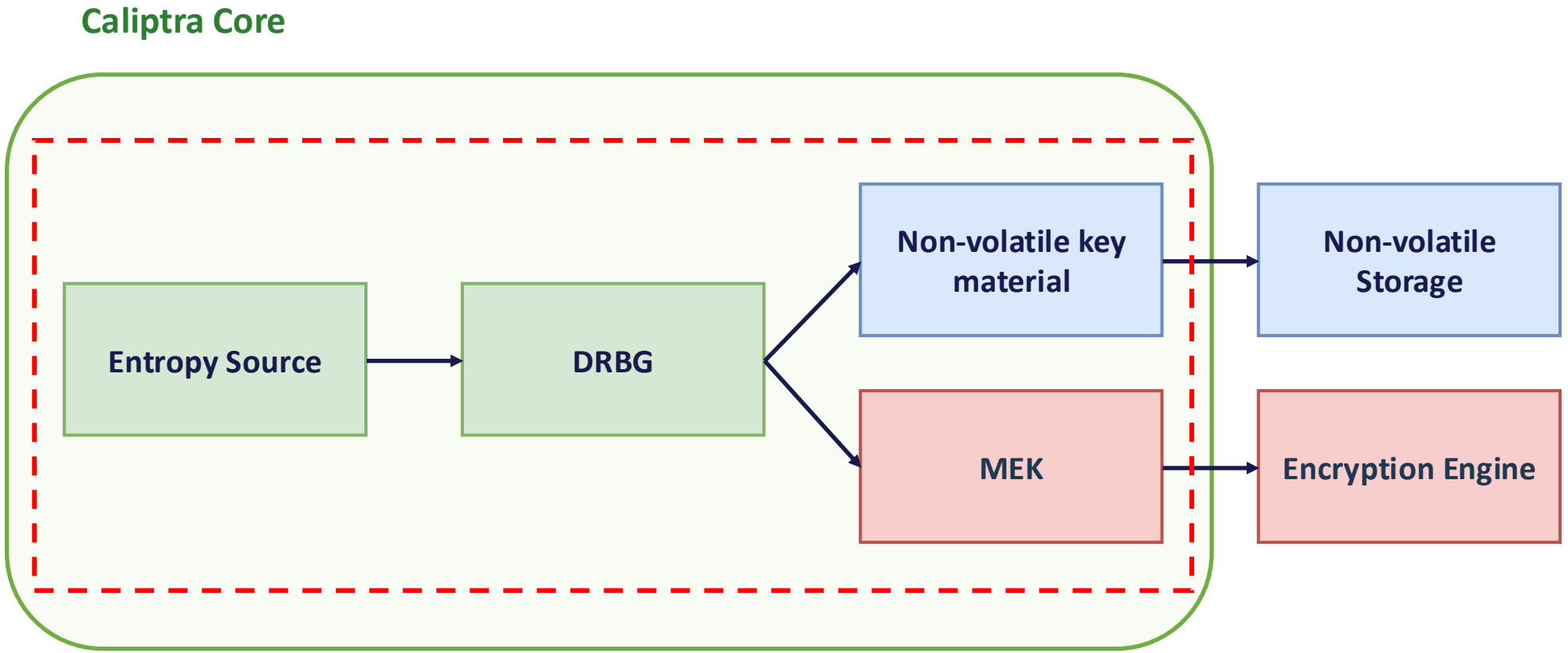
Smaller boundary ——— **Larger boundary**

- Smaller validation scope
- More CSPs cross module boundary
- More reliance on integration assumptions
- Easier to isolate Caliptra changes

- More components in validation scope
- More of the key lifecycle stays inside
- Fewer external CSP interfaces
- More implementation variants to control

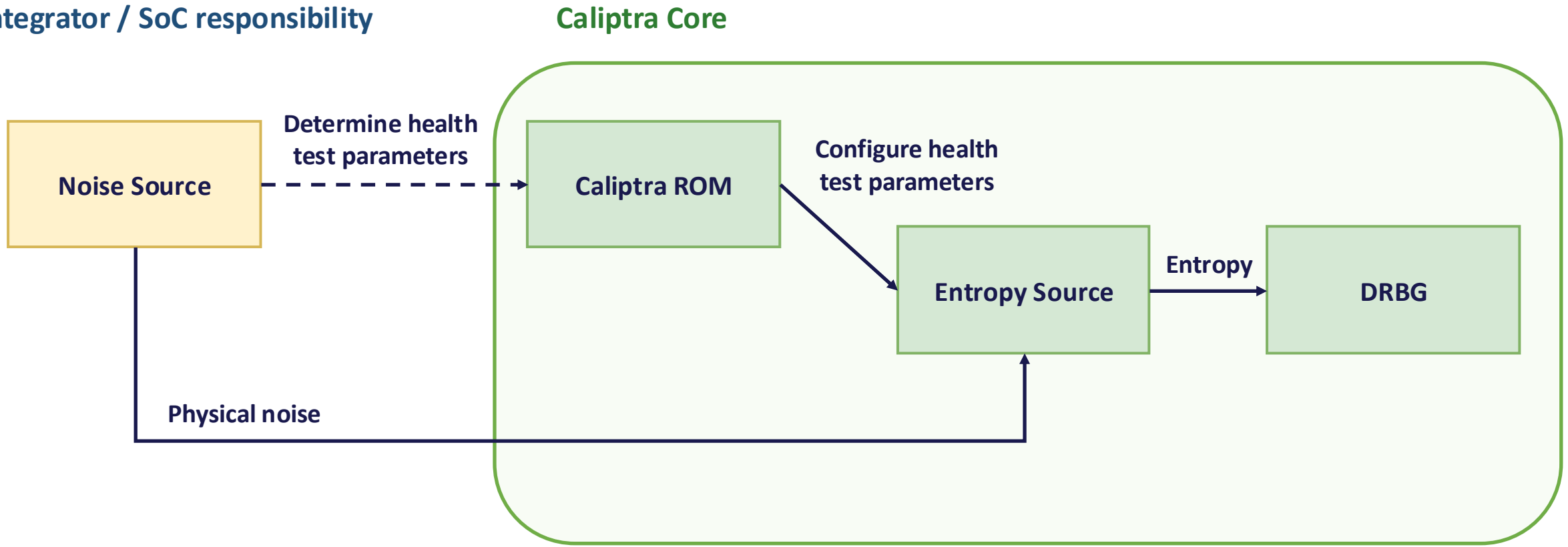
There is no universally “best” boundary — the right choice depends on the product and validation strategy.

OCP L.O.C.K. Makes DRBG Critical



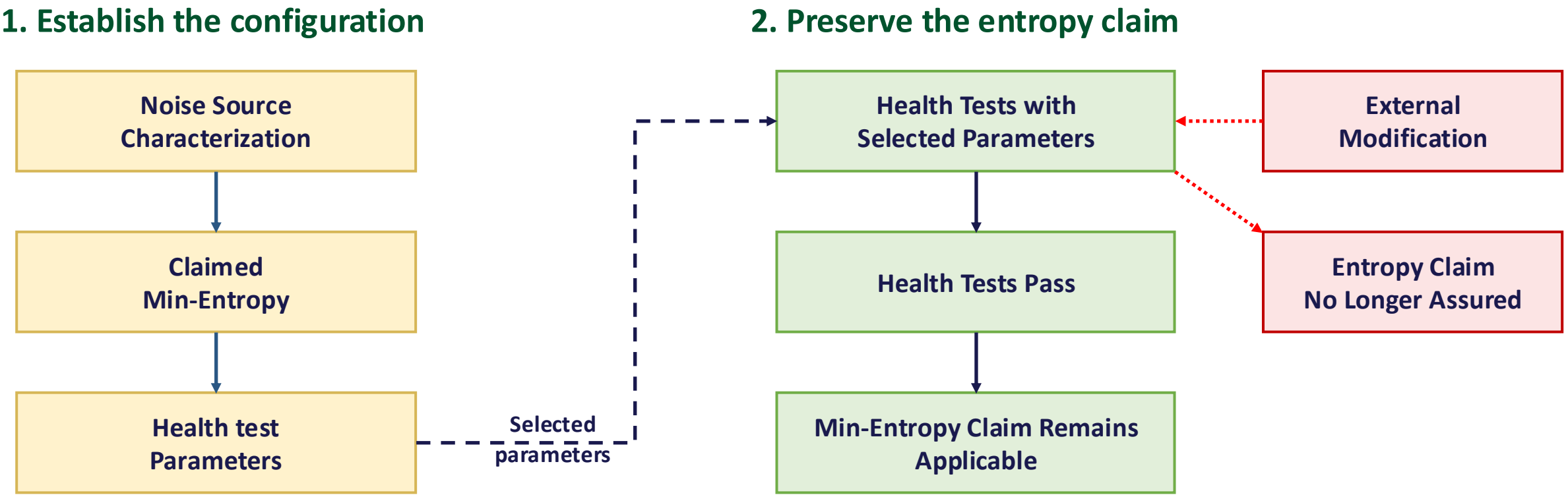
With OCP L.O.C.K., DRBG output directly contributes to security-critical key generation

DRBG Security Starts with Entropy



The strength of generated keys depends on the validated noise source → entropy source → DRBG chain complying with NIST SP 800-90

Securing the Entropy Source



External modification possible → Min-entropy claim cannot be assured

What Must Be Addressed for FIPS 140-3?

1	**Cryptographic module boundary**	Which hardware and firmware are inside the validated module?
2	**CSP lifecycle**	Where are MEKs generated, stored, released, used, and destroyed?
3	**Interfaces & key release**	How is MEK lifecycle defined in the FIPS perspective?
4	**Entropy integration**	Noise source, min-entropy characterization, and health-test configuration.
5	**Other requirements**	Additional requirements depend on the selected module boundary, product integration and validation claim.

Call to Action: Consider FIPS 140-3 Early

- Caliptra / OCP L.O.C.K. is shared open source, but each vendor validates its own product integration.
- Different products and module boundaries may lead to different FIPS requirements.
- Some requirements may be common to every implementation.

- OCP L.O.C.K. Specification
  - https://www.opencompute.org/documents/ocp-lock-specification-v1-1-final-pdf

Thank You!

